

Security and Governance in Big Data Systems

Big Data Systems
School of Data Science
University of Virginia

Introduction

- Explosive growth in volume, velocity, variety
- Distributed systems increase attack surface
- Security = protection; Governance = control & accountability
- Failures lead to financial, legal, reputational damage

Big Data Architecture Overview

- Sources: IoT, logs, transactions
- Ingestion: batch (ETL) vs streaming (Kafka)
- Storage: data lakes, warehouses, object storage
- Processing: Spark, distributed compute
- Access: BI tools, APIs, ML pipelines
- Security must span entire lifecycle

Core Security Principles

- Confidentiality: restrict unauthorized access
- Integrity: prevent tampering and ensure accuracy
- Availability: ensure uptime and resilience
- Authentication: verify identity
- Authorization: enforce permissions
- Auditing: track all access and changes

Threat Landscape

- External attackers exploiting vulnerabilities
- Insider misuse of privileged access
- Misconfigured cloud storage (common cause)
- Pipeline vulnerabilities during ingestion/processing
- ML-specific: data poisoning, model theft, model tampering

Misconfigured Cloud Storage

- > Cloud storage services designed to be flexible and accessible. The flexibility can create risk.
- > Many storage services can be made public with a single setting
 - Developer might grant public access while testing and forget to turn off

Misconfigured Cloud Storage, contd.

- > As things grow, complexity scales quickly
 - Multiple buckets/containers
 - Layered permissions (IAM policies, ACLs*, roles)
 - Cross-account access

*ACLs (Access Control Lists) are a way of specifying who is allowed to access a resource and what they're allowed to do with it.

Misconfigured Cloud Storage, contd.

> Speed over Governance

- Teams often prioritize shipping features quickly ... and security mistakes happen
- Execution versus Governance is a real tradeoff

Model-Specific Threats

1. Model Tampering (Integrity Attack)

Unauthorized modification of trained models
(e.g., bad data inserted into training set)

- > Can cause biased / malicious predictions
- > Can be hard to detect

2. Model Theft

Data Security Techniques

- Encryption at rest (disk/object storage)
- Encryption in transit (TLS/SSL)
- Role-based access control (RBAC):
roles mapped to permissions
- Attribute-based access control (ABAC):
policies based on attributes
- Data masking for sensitive fields (PII/PHI)
- Tokenization replaces sensitive values

RBAC

- Permissions are tied to roles
- Users inherit permissions through their roles

“Alice is a Data Scientist”

“Data Scientists can read Table A”

“Bob is a Data Engineer”

“Data Engineers can read Table A and Table B”

ABAC

- Access decisions made using rules based on attributes of user, resource, environment
- More flexible than RBAC

Example:

Access is granted if:

```
User.department = "Oncology"  
AND Resource.type = "Cancer dataset"  
AND Environment.device = "Managed  
device"  
AND Time = "Business hours"
```

Data Masking for Sensitive Fields

- Data stays in system
- Masking modifies sensitive data for sharing (e.g., reports, dashboards)
- Masked data still visible, but not fully exposed

Example:

Original: John Doe

Masked: Jxxx Dxx

Tokenization of Sensitive Fields

- Tokenization replaces sensitive data with random surrogate token
- Real value stored separately in secure vault

Example:

Original: John Doe

Tokenized: TKN-5r7u88c

Real value is stored elsewhere:

Token vault maps TKN-5r7u88c → John Doe

Identity & Access Management

- Centralized identity provider (SSO)
- Principle of least privilege
- Multi-factor authentication (MFA)
- Short-lived credentials and token-based access
- Regular key rotation and audit

Data Governance

Data Governance Defined

- Framework for managing data lifecycle
- Ensures data quality, consistency, and compliance
- Defines policies, roles, and processes
- Aligns data usage with business goals

Governance Framework Components

- **Data ownership:** accountable individuals
- **Data stewards:** ensure quality and compliance
- **Classification:** public, internal, confidential
- **Metadata:** schema, lineage, definitions
- **Policies:** access, retention, usage rules

Data Quality & Lineage

- Quality dimensions: accuracy, completeness, consistency
- Lineage tracks data from source to consumption
- Enables debugging and trust in analytics
- Critical for regulatory audits and reproducibility

Regulatory & Compliance

- GDPR: privacy rights and data protection
- HIPAA: healthcare data protection
- FERPA: student data protection
- CCPA: consumer privacy rights
- Requirements: minimization, consent, breach reporting
- Non-compliance leads to fines and restrictions

Governance in Practice

- Data catalogs for discovery and metadata
- Policy engines enforce rules automatically
- Audit logs capture all activity
- Automated compliance monitoring
- Trend: policy-as-code

Security in Big Data Tools

- Hadoop: Kerberos authentication
- Spark: secure configs and access control
- Cloud: IAM roles and policies
- Common issue: default insecure settings
- Regular configuration audits needed

Balancing Security & Usability

- Over-restriction slows innovation
- Under-protection increases risk
- Use tiered access models
- Enable self-service with guardrails
- Monitor behavior instead of blocking

Emerging Challenges

- AI/ML governance: bias, explainability
- Data sovereignty: cross-border restrictions
- Real-time data security challenges
- Privacy-preserving techniques (federated learning)

Best Practices

- Encrypt all sensitive data
- Implement least privilege access
- Maintain data catalog and lineage
- Continuously monitor and audit systems
- Automate governance and compliance

Key Takeaways

- Security and governance scale with data
- Must be built into architecture
- Critical for trust and competitive advantage